

ESTUDIO DE CASO 3

Divulgación de ubicación basada en navegador: Simulación controlada con enlace de Seeker

Por: Joseph Gonzalez



ZERODAY TECH LABS



Alcance	Simulación controlada de laboratorio usando un teléfono propiedad del investigador que actúa como dispositivo víctima; únicamente con fines educativos y analíticos
Entorno	Kali Linux, Seeker, túnel ngrok, navegador móvil, teléfono Android propiedad del investigador, artefactos de URL/IP/ubicación públicos redactados
Evidencia principal	Captura de lanzamiento de Seeker, captura del túnel ngrok, captura del listener de solicitudes, captura del permiso de ubicación móvil, captura de terminal redactada de campos de dispositivo/ubicación

Uso únicamente educativo y analítico. La URL pública, la IP, el dispositivo y los detalles de ubicación mostrados en las figuras están redactados.

Introducción

Los navegadores móviles solicitan permisos sensibles de forma rutinaria durante la actividad web ordinaria, especialmente cuando un sitio afirma que necesita la ubicación para personalizar la experiencia. Eso crea un tipo de exposición diferente al phishing de credenciales o al sideloading de aplicaciones maliciosas: el usuario no necesita instalar software ni escribir una contraseña. El riesgo aparece en el aviso de permiso, donde una página creíble puede persuadir al usuario para compartir datos de ubicación.

Este estudio de caso examina una única simulación controlada con Seeker usando un túnel público temporal y un teléfono propiedad del investigador que actúa como dispositivo víctima. El objetivo fue documentar cómo se veía la página, cómo el navegador presentó la solicitud de ubicación, qué datos aparecieron en la terminal después de conceder el permiso y por qué esto importa para usuarios individuales fuera del laboratorio.

Metodología

Se realizó una simulación de ciberseguridad controlada en un entorno de laboratorio aislado con Kali Linux, Seeker, un túnel ngrok y un navegador móvil en un teléfono Android propiedad del investigador. El alcance se limitó a infraestructura autocontrolada, un enlace temporal de prueba y una interacción consentida por el investigador. No participaron víctimas reales, dispositivos de terceros, cuentas de producción ni rastreo no autorizado. La URL pública, la IP, el dispositivo y los artefactos de ubicación se redactaron antes de la publicación.

1. Descripción general

Seeker es útil como herramienta de enseñanza defensiva porque muestra cómo una página web puede solicitar acceso a la ubicación y registrar detalles de dispositivo y red proporcionados por el navegador una vez que el usuario concede el permiso. En este escenario, la pregunta analítica fue si una página creíble con estilo "cerca de ti", entregada mediante un túnel público temporal, podía producir datos observables de ubicación y dispositivo desde un teléfono que aceptó voluntariamente el aviso del navegador.

2. Configuración del laboratorio

El host de laboratorio se usó para iniciar el entorno Seeker y seleccionar una plantilla con tema de ubicación. Como se muestra en la Figura 1, las plantillas disponibles se presentaron desde la terminal antes de preparar la página de prueba. Como se muestra en la Figura 2, luego se usó un túnel temporal para que la página local de prueba fuera accesible desde el teléfono. La importancia de esta etapa no es la secuencia exacta de comandos, sino la transición de una página web local a un enlace público que un navegador móvil podía abrir.

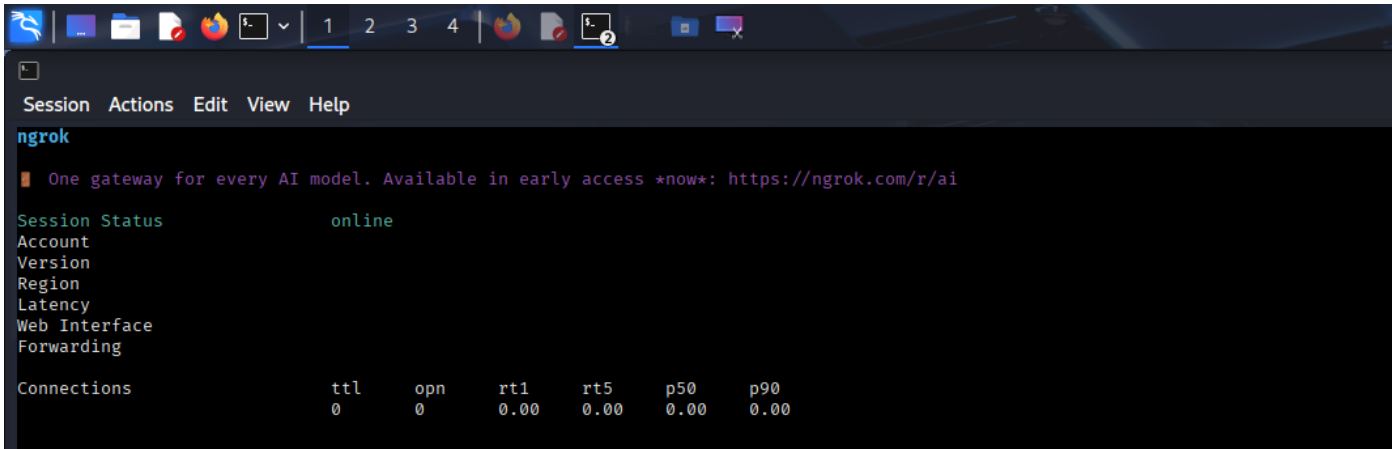


Figura 1. Entorno de lanzamiento de Seeker en el host de laboratorio, mostrando la etapa de selección de plantilla usada en la simulación controlada.

[illegible]

Figura 2. Sesión de túnel temporal usada para exponer la página local de prueba mediante una ruta de reenvío pública, con URL y detalles de cuenta redactados.

3. Entrega del enlace público y aviso de permiso

Después de preparar el enlace público de prueba, el teléfono abrió la página con tema de ubicación como dispositivo víctima simulado. Como se muestra en la Figura 3, apareció actividad de solicitudes en la sesión del túnel después de visitar la página. Como se muestra en la Figura 4, el navegador móvil mostró una solicitud de permiso de ubicación para el sitio. Este es el punto de decisión clave: la exposición depende de que el usuario conceda acceso, no de una evasión invisible del modelo de permisos del navegador.

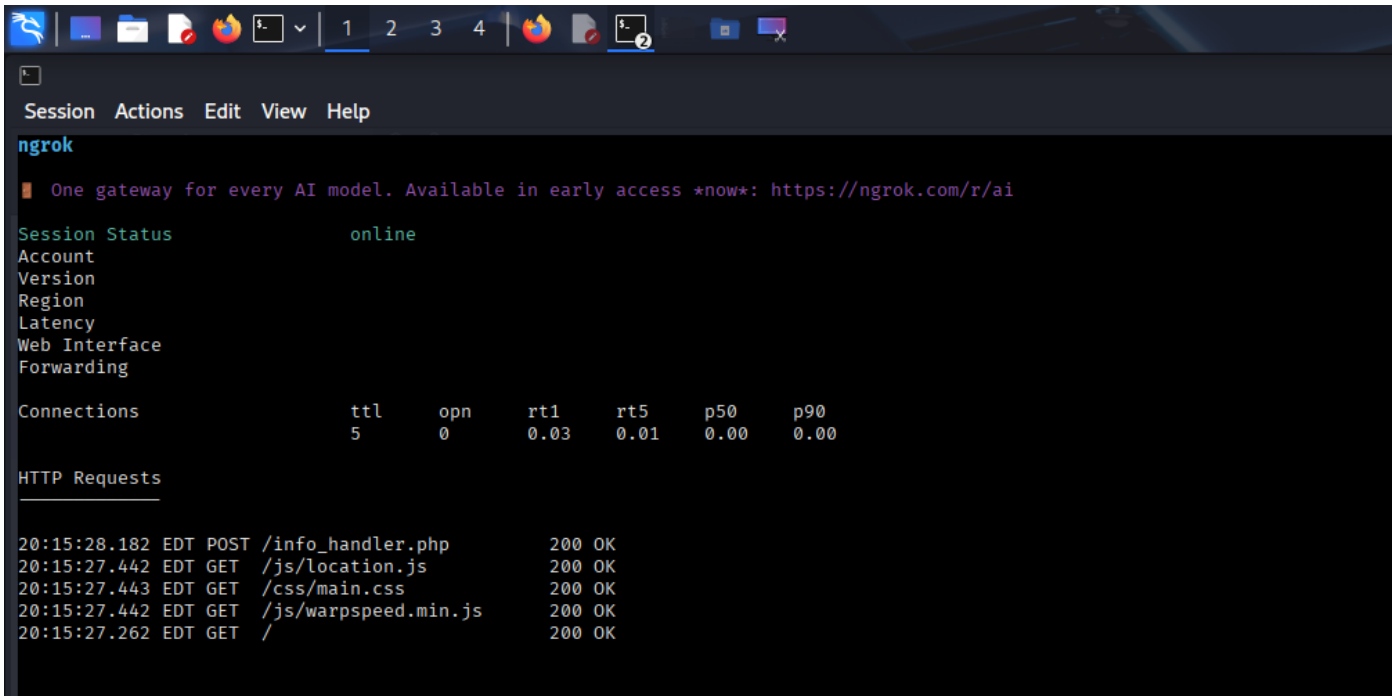


Figura 3. Vista del listener del túnel que muestra solicitudes web del teléfono después de abrir el enlace público de prueba, con detalles de reenvío redactados.

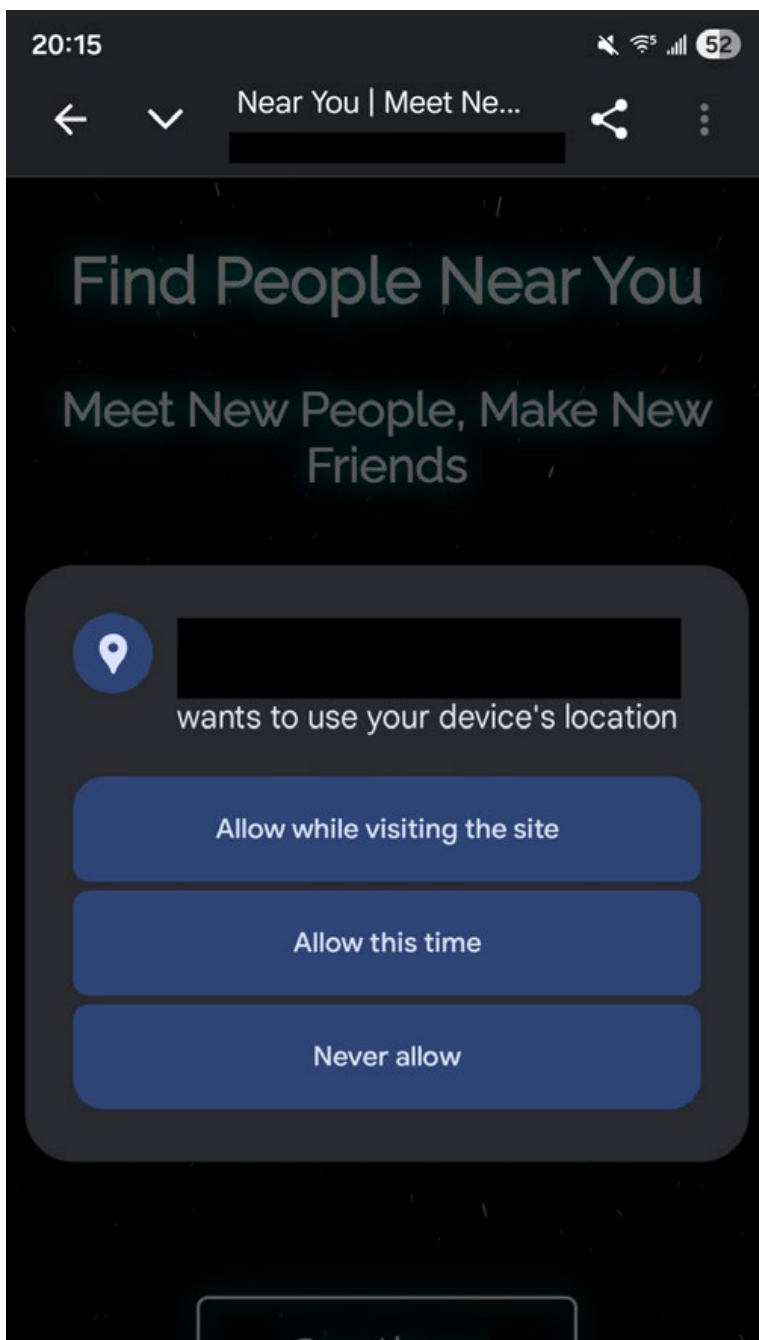


Figura 4. Teléfono propiedad del investigador actuando como dispositivo víctima, abriendo el enlace y recibiendo un aviso de permiso de ubicación del navegador con la URL pública redactada.

4. Evidencia recopilada

Como se muestra en la Figura 5, la salida de la terminal registró campos relacionados con dispositivo, navegador, red y ubicación después de que el teléfono permitió el acceso a la ubicación. El punto probatorio más importante es que el aviso del navegador creó una compuerta de consentimiento: una vez concedido el permiso, el contexto sensible se devolvió a la página receptora y se hizo visible en la terminal de recopilación. Las redacciones preservan el valor forense del artefacto y eliminan datos privados de IP, URL y ubicación.

Figura 5. Captura redactada de la terminal de Seeker que muestra campos de dispositivo, red y ubicación proporcionados por el navegador después de conceder permiso durante la prueba controlada.

5. Por qué ocurrió la divulgación

La divulgación ocurrió porque el sitio solicitó un permiso que los navegadores están diseñados para admitir, y el usuario lo concedió. En otras palabras, no fue un compromiso silencioso del sistema operativo. Fue una exposición impulsada por consentimiento, creada por un pretexto convincente, un enlace público y un aviso de permiso que parecía lo bastante rutinario como para aprobarse.

El tema "cerca de ti" hizo que la solicitud pareciera contextualmente adecuada: una página que afirma mostrar personas cercanas parece necesitar ubicación de forma natural. El navegador sí mostró el origen del sitio, pero los usuarios suelen enfocarse en el lenguaje de la tarea y en los grandes botones de aprobación en lugar de verificar el dominio temporal. El túnel también importó porque convirtió un servicio local en una página pública accesible, permitiendo que el teléfono interactuara con el contenido alojado en el laboratorio desde fuera del contexto de localhost.

6. Impacto real para la persona

Para un usuario individual, conceder ubicación a una página engañosa puede exponer más que un solo dato. La ubicación puede revelar dónde alguien vive, trabaja, estudia, practica su fe o pasa tiempo con su familia. Cuando se combina con la dirección IP pública, el tipo de dispositivo, la versión del navegador y la información del proveedor de red, puede apoyar phishing dirigido, acoso, doxxing, stalking o intentos de ingeniería social que se sienten inusualmente personales.

El riesgo es especialmente serio en teléfonos porque las personas tratan los avisos de permisos móviles como algo rutinario. Un usuario puede aprobar la ubicación mientras está distraído y luego olvidar que el sitio alguna vez la solicitó. Incluso si la página no instala malware, los datos recopilados aún pueden ayudar a un atacante a crear un perfil de la persona, programar mensajes futuros o diseñar un señuelo de seguimiento más creíble.

7. Mitigación, endurecimiento y prevención

La solución práctica es reducir las concesiones innecesarias de ubicación y tratar los avisos de permiso como decisiones de seguridad. Los usuarios deben denegar solicitudes de ubicación de enlaces desconocidos, evitar abrir enlaces con tema de ubicación desde mensajes o redes sociales, y revisar la barra de direcciones del navegador antes de aprobar el acceso. En los teléfonos, la configuración del navegador debe revisarse con regularidad para eliminar permisos antiguos de sitios.

Si se aprobó un aviso de ubicación sospechoso, el usuario debe revocar el permiso del sitio, borrar los datos del sitio, cerrar la pestaña y evitar volver a interactuar con la página. Para la prevención a largo plazo, mantenga actualizados el navegador móvil y el sistema operativo, prefiera aplicaciones oficiales y dominios conocidos, desactive la ubicación precisa cuando no sea necesaria y enseñe a los usuarios que "Permitir esta vez" aún libera datos sensibles para esa sesión. Una VPN puede ocultar parte de la información de red, pero no impide la divulgación de ubicación por GPS o concedida por el navegador una vez aceptado el permiso.

8. Consideración ética

Este estudio de caso se realizó estrictamente con fines educativos y analíticos. El sitio, el túnel, la sesión de terminal y la interacción con el teléfono fueron operados por el investigador en un escenario de prueba acotado. El teléfono usado en las capturas actuaba intencionalmente como dispositivo víctima, y todos los valores sensibles de URL, IP y ubicación se redactaron antes de preparar el informe.

El valor del caso es defensivo y no operacional. Demuestra cómo puede ocurrir una exposición de datos basada en permisos sin instalación de malware y sin entrada de credenciales, simplemente porque se persuade al usuario para aprobar una solicitud del navegador. Esto hace que el caso sea útil para formación de concienciación, seguridad de dispositivos familiares, conversaciones de privacidad móvil y planificación de respuesta a incidentes.

En última instancia, la lección es clara: los avisos de permisos del navegador no son ventanas emergentes inofensivas. Son decisiones de confianza. Cuando un sitio pide ubicación, el hábito más seguro es pausar, verificar el origen y denegar la solicitud salvo que la necesidad sea legítima y esperada.